



Plain English Guide

SDLC, the Azure migration and the cybersecurity review explained without jargon, using maintenance and hydraulic comparisons, with a full glossary.

Prepared for	Mohammed Al-Jahdali
Role	Maintenance Instructor Lead
Purpose	Meeting preparation
Platform	TAQA Knowledge Hub

INTERNAL USE

Contents

1. Start here	3
2. The one picture that explains everything	3
3. What each piece behind the panel actually is	4
4. SDLC explained	4
5. Why testing must come later	6
6. GitHub, explained from zero	7
7. The Azure migration explained	8
8. The cybersecurity review explained	9
9. Twenty questions and your answers	11
10. How to run the meeting	13
11. Glossary	14
12. If you remember only five things	16

1. Start here

This guide assumes you know nothing about IT, and explains everything using equipment and maintenance ideas you already work with every day.

Read section 2 first. Once you understand that one picture, the rest follows.

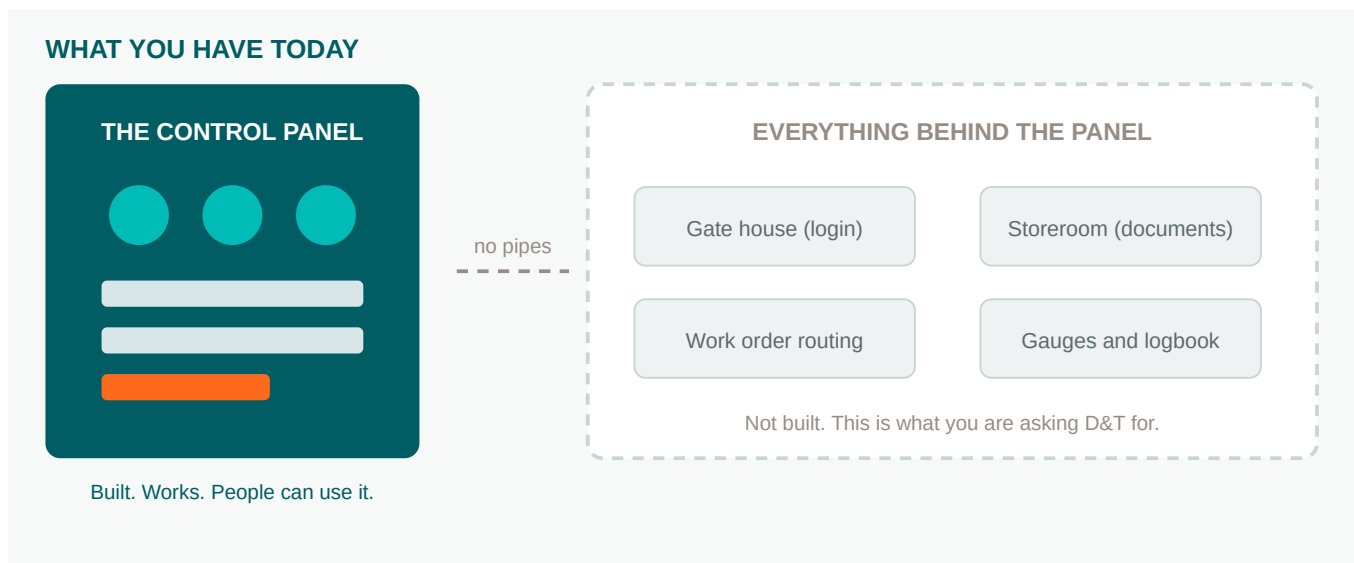
There is a full glossary at the end. Every term in bold appears there.

2. The one picture that explains everything

Think of what you have built as **a control panel for a plant that is not yet piped up**.

The panel is finished. The buttons are mounted, the gauges are fitted, the labels are printed, the layout makes sense to an operator. You can press buttons and lights come on.

What is missing is everything behind the panel. There are no pipes to the reservoir. No pump. No valves. No pressure sensors feeding the gauges. The gauges currently show numbers that were painted on rather than measured.



That is the entire situation. Everything anyone asks you over the next three months is about one of those two halves.

The panel is yours. You built it, it works, it is finished.

Everything behind the panel belongs to D&T, because only they can provide it. It needs company infrastructure, company approvals and company money.

If you remember nothing else, remember this sentence:

The front is done. The back needs D&T. That is the whole request.

3. What each piece behind the panel actually is

The IT name	What it really is	The equipment version
Entra ID	The system that checks who you are when you arrive	The gate house and badge reader
SharePoint	Where the actual document files are stored	The storeroom where the parts live
Microsoft Graph	The way the panel asks the storeroom for a document	The requisition slip you send to stores
Power Automate	The system that routes an approval to the right person	Work order routing in the CMMS
Azure	Microsoft's rented plant capacity	Renting compressor capacity instead of running your own
Application Insights	Real usage figures	Proper instrumentation on the machine
Defender	Scans files for malware before they are stored	Incoming material inspection at the gate
Purview	Labels documents by sensitivity and sets how long to keep them	Document control and retention schedule

None of these is new software TAQA has to buy. **TAQA already owns all of it.** It is like having a fully equipped workshop already paid for and simply not having been issued the key.

4. SDLC explained

What the letters mean

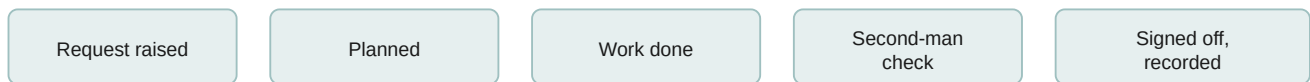
SDLC stands for **Software Development Life Cycle**. Ignore the words. Here is what it actually means:

A written, followed process for how software gets requested, built, checked and released, and proof that you follow it.

You already run exactly this system, and you already teach it. It is a **maintenance work order**.

Your work order versus their SDLC

MAINTENANCE WORK ORDER



Same process. Different words.

SOFTWARE SDLC



That is all SDLC is. If someone in the meeting says "do you have a defined SDLC?", they are asking: *do you have a work order system for your software, and can you prove people follow it?*

The framework TAQA uses

TAQA assesses against something called the **Kosli** template. It has **13 checks**, in three groups.

Group 1: Build. Do you know exactly what you built and what went into it?

Equipment version: can you produce the parts list, the material certificates and the batch numbers for a rebuild?

The check	Plain meaning	Your status
Artifact Binary Provenance	Can you prove exactly which version is running?	Done
Version Control	Is every change recorded with who and when?	Done
Defined Toolchain	Do you know what tools built it?	Done
Dependency Management	Do you know every outside part you used?	Done

You score 4 out of 4 here, and one reason is genuinely strong. Most software is assembled from hundreds of parts made by strangers. Yours uses **one**. In equipment terms, you machined nearly everything in house instead of buying a crate of unmarked bearings from an unknown supplier. Say that in the meeting.

Group 2: Process. Is there a second pair of eyes before anything goes live?

Equipment version: does a critical job get a second-man check and a permit before energising?

The check	Plain meaning	Your status
Code Review	Does someone else check changes?	Waiting on D&T naming a reviewer
Quality Assurance	Is it tested?	Partly. Tested by hand, not automatically
Security Scanning	Has it been checked for weaknesses?	Partly. Done by hand, tools come later
Deployment Approvals	Is there a sign-off before release?	Waiting, needs the reviewer first

Group 3: Runtime. Once it is running, do you watch it and know who owns it?

Equipment version: is it on the PM schedule, does it have gauges, and whose name is on the asset?

The check	Plain meaning	Your status
Change Records	Is there a history file?	Done
Deployment Controls	Is release controlled and repeatable?	Partly
Secrets Management	Are passwords and keys kept safe?	Done for now, because there are none yet
Service Ownership	Whose asset is it?	Waiting. Nobody in IT owns it yet
Workload Monitoring	Are there gauges on it?	Waiting. There is no machine to gauge yet

Your score, and how to say it

6 done. 3 partly. 4 waiting.

The critical sentence, and the one that keeps you out of the corner:

The four that are waiting are not waiting on me. Three need D&T to name an owner and a reviewer.
The fourth needs a server, and there isn't one yet.

You cannot put a gauge on a pump that has not been installed. That is not a failure. That is sequence.

5. Why testing must come later

This is the point people find hardest, so here is the analogy to use.

Nobody pressure-tests a hydraulic system before the pipes are connected.

You assemble it, you connect it, you fill it, and *then* you test it. Testing an empty frame proves nothing, costs money, and tells you nothing about the system that will actually run.

TESTING NOW

No login to break into
No server to attack
No documents to steal

Pressure-testing an empty frame

TESTING AFTER PHASE 2

Real login to test
Real server to probe
Real documents to protect

Testing the system that will run

Your line in the meeting:

I am not avoiding the security test. I am asking for it to happen after the system is connected, so it tests the real thing. Testing it now is pressure-testing an empty frame, and we would have to pay for the whole test again afterwards.

That is a professional argument, not an excuse, and any competent security lead will accept it.

6. GitHub, explained from zero

People will mention GitHub constantly. Here is the whole thing.

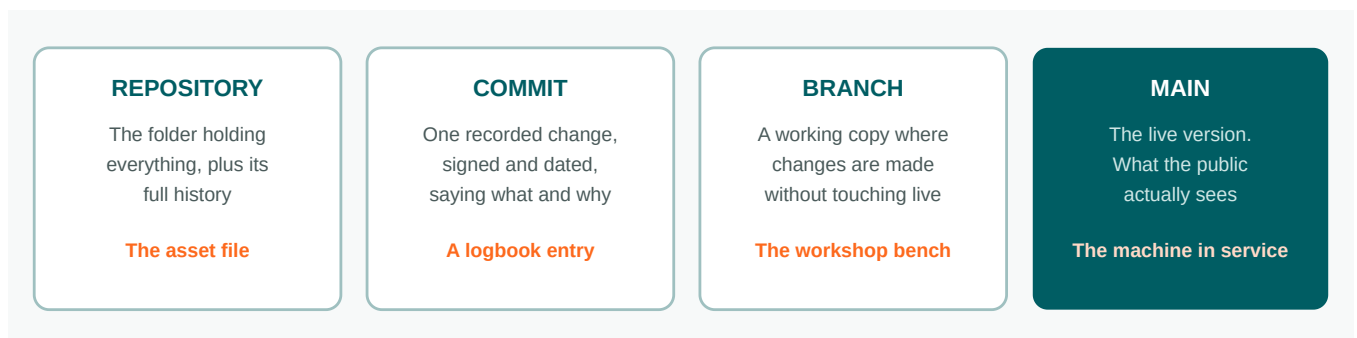
What it is

GitHub is a website that stores your files **and remembers every version of them, forever**.

That is it. It is a filing cabinet with a perfect memory.

Equipment version: it is the equipment history file for your software. Every change recorded, with who made it, when, and why. You can go back to any previous state, exactly as it was.

The four words you need



Work happens on a **branch**, which is the bench. When it is finished and checked, it is merged into **main**, which is the machine in service. Every step is a **commit**, and all of it lives in the **repository**.

Why security people care about it

Two reasons, and both are on their checklist.

It proves what is running. If something breaks, you can see exactly which change caused it, who made it and when. Nothing is untraceable.

It is where the second-man check happens. A rule can be set so nothing reaches **main** without another person approving it. That rule is called **branch protection**, and right now **it is switched off on your repository**. That is why "Code Review" shows as waiting in the SDLC assessment.

The bit that will come up

Your repository is currently **public**, meaning anyone on the internet can read it.

That is not an accident. GitHub's free plan requires a public repository to host a free preview link, and that link is how people have been viewing the Hub. No passwords and no real documents are in it, only the page code and document titles.

Your answer, ready to use:

It is public because the free preview link requires it. It becomes private the day TAQA hosting is live. No credentials and no operational documents have ever been in it.

What you actually need to do with GitHub

Almost nothing. D&T will copy the repository into a TAQA-owned account. You keep working the way you always have. The only real change is that after handover, your work goes onto a branch and someone approves it before it reaches main.

That is the second-man check, and it is a control **you asked for** in the security assessment. It is not a restriction being imposed on you.

7. The Azure migration explained

What "migration" means here

Almost nothing. That is genuinely the point.

Your platform is **42 files in a folder**. There is no database to export, no server to rebuild, no data to convert. Migration means copying a folder to a company-owned address and then connecting the services behind it.

Equipment version: you are not relocating a plant. You are moving a toolbox to a company-owned workshop and then getting the utilities connected.

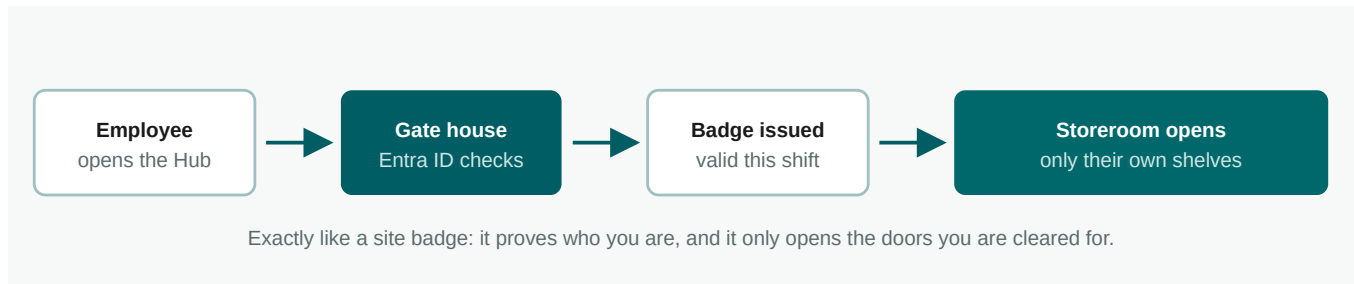
The five phases

- 1 Identity: the gate house**
People sign in with their TAQA account. 2 to 3 days.
- 2 Documents: the storeroom**
Real files appear instead of placeholders. 8 to 13 days.
- 3 Workflow: the routing**
Upload and support forms actually work. 8 to 13 days.
- 4 Gauges and protection**
Real usage figures, malware scanning, labels. 6 to 10 days.
- 5 Operations: PM schedule and handover**

Only ask for Phase 1. It is small, it is cheap, and everything else is blocked behind it anyway. Getting one phase approved is far easier than getting five approved, and once people can log in with their TAQA account they can

see it is real.

How logging in will work



The important detail, and it is the answer to a question you will definitely be asked:

The platform never holds anyone's password. It never gets its own master key. It carries the badge of whoever is signed in, so it can only reach what that person could already reach.

In equipment terms: the platform does not get a master key to the storeroom. It walks in with your badge.

The one thing to keep asking for

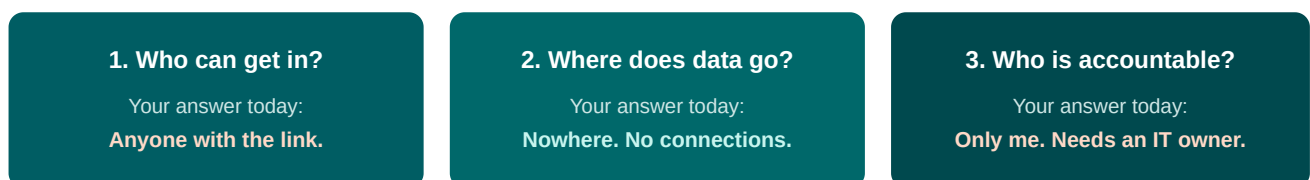
The App Registration. This is permission for your panel to talk to the gate house at all. Without it, nothing in Phase 1 can start, and Phases 2 to 5 sit behind Phase 1.

It takes the longest to approve because it goes through security. Ask about it in every conversation until the answer is "done".

8. The cybersecurity review explained

What they are actually checking

Security people ask three questions. Everything else is detail.



Two of those three answers are uncomfortable, and both are fixed by the same thing: **the D&T handover**. That is why you keep steering the conversation back to it.

Question 2 is your strongest card

Your platform makes **no connections to anything**. Not to Google, not to Microsoft, not to any outside company. Every button either changes what is on the screen or saves a preference on that person's own device.

Equipment version: it is a completely closed loop. Nothing is piped in, nothing is piped out.

That is unusual and it is genuinely good. Most systems that come to a security review are leaking data to a dozen suppliers.

What we found and fixed

Being able to say "we found problems and fixed them" is stronger than "we found nothing". Nobody believes "we found nothing".

What was wrong	The equipment version	Status
Four outside services were being contacted, including one receiving names and emails	Four subcontractors were on site without a gate pass, and one was taking paperwork off site	Removed
A filename could carry a hidden instruction that the page would run	Someone could put contaminated fluid in through the fill port because there was no filter on it	Fixed and retested
Programs (<code>.exe</code>) could be attached as uploads	The storeroom would accept an unlabelled drum with no material certificate	Blocked
A warning message was silently broken, so a rejected file failed with no message	The alarm lamp was fitted but not wired	Fixed

What is still open

Ten items. Here are the four they will press on, in plain terms.

No login. Anyone with the address can browse it. This is why no real documents have been loaded yet, and you should say that before they ask.

Documents will cache on personal phones. The platform works offline, which means it keeps a copy on the device. Once real procedures are loaded, TAQA documents will sit on whatever phone someone installed it on, including personal ones. *Nobody has decided whether that is acceptable.* Raise this yourself: it is the single best thing you can bring to the meeting, because it shows you are thinking about their job, not just yours.

The forms remember what people type. So a half-finished support ticket survives a refresh. On that form people type their email, their employee number, and the well or rig involved. That is saved on the device until they submit. It never leaves the device, but it is there.

Nobody in IT owns it. No support model, no escalation path, no cover when you are on leave.

The one on your own screen

The home page shows five headline numbers and every one is wrong, including **"Registered Users: 1,200"** on a platform that has no accounts at all.

Nobody will believe the rest of your numbers if that one is on the screen in front of them. It is a five-minute fix and it should be done before the next demonstration.

9. Twenty questions and your answers

Short answers. If you do not know something, say "**Let me confirm and come back to you**", then ask me. Never guess in front of them.

They ask	You say
What is it built with?	Plain web pages. No framework, no database, no server.
How big is it?	42 files, about 2 megabytes.
What does it cost?	Nothing new. It runs on the free tier and uses Microsoft services TAQA already owns.
Who built it?	I did, at the Learning Center.
Is there a login?	Not yet. That is the main thing I need from D&T.
Where are the documents stored?	Nowhere yet. The viewer shows a placeholder. Real files come with SharePoint.
Does it send data anywhere?	No. It makes no outside connections at all. That was verified by recording all network traffic.
Any third-party software?	One small open-source library for QR codes. Nothing else. No package manager.
Has it been security tested?	Code review, a full password scan of the entire history, and browser testing of every page. Penetration testing should come after the integration.
Why not test it now?	It would be pressure-testing an empty frame. No login, no server, no data. We would pay for the whole test twice.
Were any problems found?	Yes. Four, all fixed the same day. I can walk you through them.
Is the code reviewed?	Not yet. I need D&T to name a reviewer. Right now I am the only pair of eyes.
Is it backed up?	The code is in version control with full history. There is no other data yet.
Who supports it?	Nobody in IT yet. That is one of my three asks.
Why is it on public GitHub?	The free preview link requires it. It goes private the day TAQA hosting is live. No passwords or real documents are in it.
Is there AI in it?	No. The page labelled AI Search does keyword matching against a fixed list. Nothing is sent to any AI service.
What about Arabic?	It is English only today. If Arabic is needed, that is a separate piece of work to scope.
Can people use it offline?	Yes, and that is a question for you: it means documents cache onto the device, including personal phones.
How long will it take?	One to two days to be running on TAQA Azure. Two to three more for login, once the App Registration is approved.
What do you need from us?	An IT coordinator, a technical reviewer, and the Azure App Registration.

10. How to run the meeting

Open by naming the weaknesses yourself. Say this in the first two minutes:

This was built outside IT governance and I want it brought inside. Here is everything I know is wrong with it.

Security people spend their whole working life dragging systems into the light. Someone who walks in already holding the torch is treated completely differently from someone defending a project.

Never oversell. If something does not work, say so. The upload button does nothing. The support form sends nothing. The home page numbers are wrong. Saying it first costs you nothing. Being caught costs you everything.

Keep returning to the three asks. Whatever the question, the answer ends in the same place:

1. A named IT coordinator
2. A named technical reviewer
3. The Azure App Registration

Use your own language. You are a maintenance instructor talking to engineers. "You do not pressure-test an empty frame" will land better in that room than any piece of IT vocabulary, and it shows you understand the principle rather than the buzzword.

11. Glossary

The words they will use

Term	What it means
API	A defined way for two systems to ask each other for things. A requisition form between departments.
App Registration	Permission for your platform to talk to Microsoft's login system. The thing you keep asking for.
Application Insights	Microsoft's tool for real usage figures. Instrumentation on the machine.
Authentication	Proving who you are. Showing your badge.
Authorisation	What you are allowed to do once inside. Your permit to work.
Azure	Microsoft's rented computing. Renting plant capacity instead of building your own.
Backend	Everything behind the screen: server, database, storage. The pipework. You do not have one.
Branch protection	A rule that stops anyone changing the live version without a second signature. Lock-out tag-out.
Cache	A local copy kept for speed or offline use. A small stock of parts kept at the work site.
CI/CD	Automatic release when a change is approved. An automated handover to operations.
Cloud	Someone else's computers, rented.
Commit	One recorded change, with who made it, when, and why. A logbook entry.
CSP	A rule list of which outside sites the page may contact. The approved contractor list at the gate.
DAST	Automated attack testing against a running system.
Defender	Microsoft's malware scanner. Incoming material inspection.
Delegated permission	The platform acts using your badge, not its own master key.
Dependency	Outside code your software relies on. A bought-in component. You have one.
Deployment	Putting a new version live. Commissioning.
Encryption	Scrambling data so only the right holder can read it. A sealed container.
Entra ID	Microsoft's identity system, formerly Azure AD. The gate house.
Frontend	What the user sees and clicks. The control panel. This is what you built.
Git	The system that records every change ever made. The equipment history file.
GitHub	The website where that history is stored and shared.

Term	What it means
Graph API	The way to ask Microsoft 365 for documents and user details. The requisition slip.
HTTPS	An encrypted connection. A sealed line rather than an open one.
Kosli	The template TAQA assesses software processes against. Their inspection checklist.
localStorage	A small store inside the browser on that one device. A notebook in the operator's pocket.
MFA	A second proof of identity beyond a password. Badge plus PIN.
Migration	Moving a system from one place to another.
Package manager	A tool that pulls in hundreds of outside components automatically. You do not use one, which is good.
Penetration test	An authorised attempt to break in, to find weaknesses. A pressure test.
Permissions	Who may do what.
Power Automate	Microsoft's routing tool for approvals and notifications.
PWA	A website that installs on a phone and works offline.
Repository (repo)	The folder holding the code and its full history.
SAST	Automated scanning of the code for weaknesses.
SDLC	Software Development Life Cycle. A work order system for software.
Sentinel	Microsoft's security monitoring and alerting system.
SharePoint	Microsoft's document storage. The storeroom.
Static site	A site with no server behind it. Pages are served exactly as written. Yours is one.
Supply chain risk	Risk from outside components you did not write. You have almost none.
Token	A temporary pass issued after login. A shift badge that expires.
Version control	Recording every change so any version can be reproduced.
XSS	A trick where hidden instructions get into a page and run. Contamination through an unfiltered port. This was found in yours and fixed.

The abbreviations in your documents

Short	Full
D&T	Data and Technology, the TAQA IT function
DT-01 to DT-21	Numbered tasks for D&T in the handover plan
LC-01 to LC-07	Numbered tasks for the Learning Center, meaning you
R-01 to R-13	Numbered open risks in the cybersecurity pack
CMP-01 to CMP-06	Compliance items in the handover plan
NCA ECC / CCC	Saudi National Cybersecurity Authority controls. Ask whether they apply
PDPL	Saudi Personal Data Protection Law
OWASP	The recognised body for web application security standards
SLA	Service Level Agreement, a guaranteed level of availability

12. If you remember only five things

1. **The front is done. The back needs D&T.** That is the whole request.
2. **It connects to nothing.** No outside services at all. Verified, not assumed.
3. **You do not pressure-test an empty frame.** Security testing comes after the system is connected.
4. **Say the weaknesses first.** No login, no real documents, forms that do nothing, wrong numbers on the home page.
5. **Three asks, every time.** An IT coordinator. A technical reviewer. The App Registration.

Mohammed Al-Jahdali. mohammed.jahdali@tq.com. +966 54 773 3744